NAME: SIVARANJANII.M
ROLL:NO:241901109

EXPERIMENT 11

PERFORM CROSS-SITE REQUEST FORGERY (CSRF) ATTACK

AIM:

To study and demonstrate a Cross-Site Request Forgery (CSRF) scenario in the intentionally vulnerable DVWA application by inspecting the password-change request at Low security using Burp Suite.

ALGORITHM:

1. Start the DVWA service in Kali and open http://127.0.0.1:42001 in the browser.
2. Log in to DVWA and open DVWA Security. Set the security level to Low and save the setting.
3. Select Vulnerabilities → CSRF to display the password-change form.
4. Open Burp Suite and use Proxy → HTTP history to locate the request sent by the CSRF page.
5. Inspect the request parameters. The captured request contains password_new, password_conf, and Change=Change. The displayed request does not contain a user_token parameter.
6. Inspect the response. The supplied capture shows HTTP/1.1 200 OK and the DVWA CSRF page HTML. This response confirms that the page was returned, but by itself does not prove that the password was changed.
7. If required by the lab instructor, perform a controlled proof-of-concept only against this local DVWA instance, then verify the outcome using DVWA's Test Credentials control. Do not test against any real or third-party website.

TOOLS REQUIRED

- Kali Linux (WSL)
- Damn Vulnerable Web Application (DVWA)
- Burp Suite Community Edition
- Web browser
- Text editor and local HTTP server (for the optional proof-of-concept page)

OUTPUT:

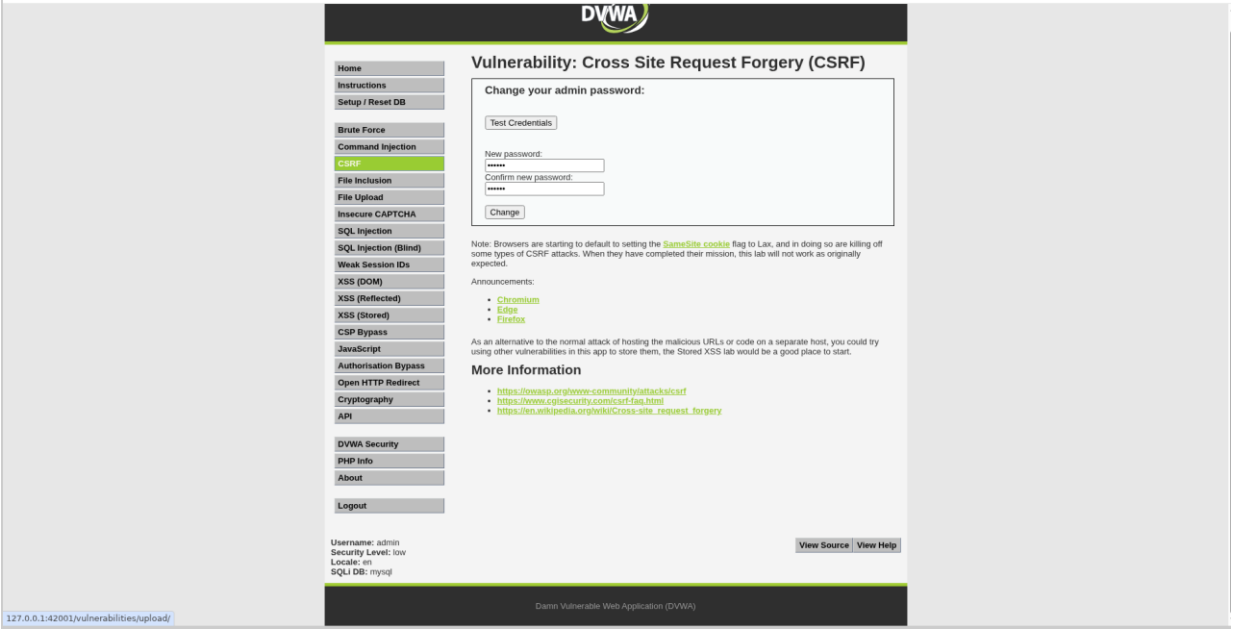


Fig 1: DVWA CSRF password-change page at Low security.

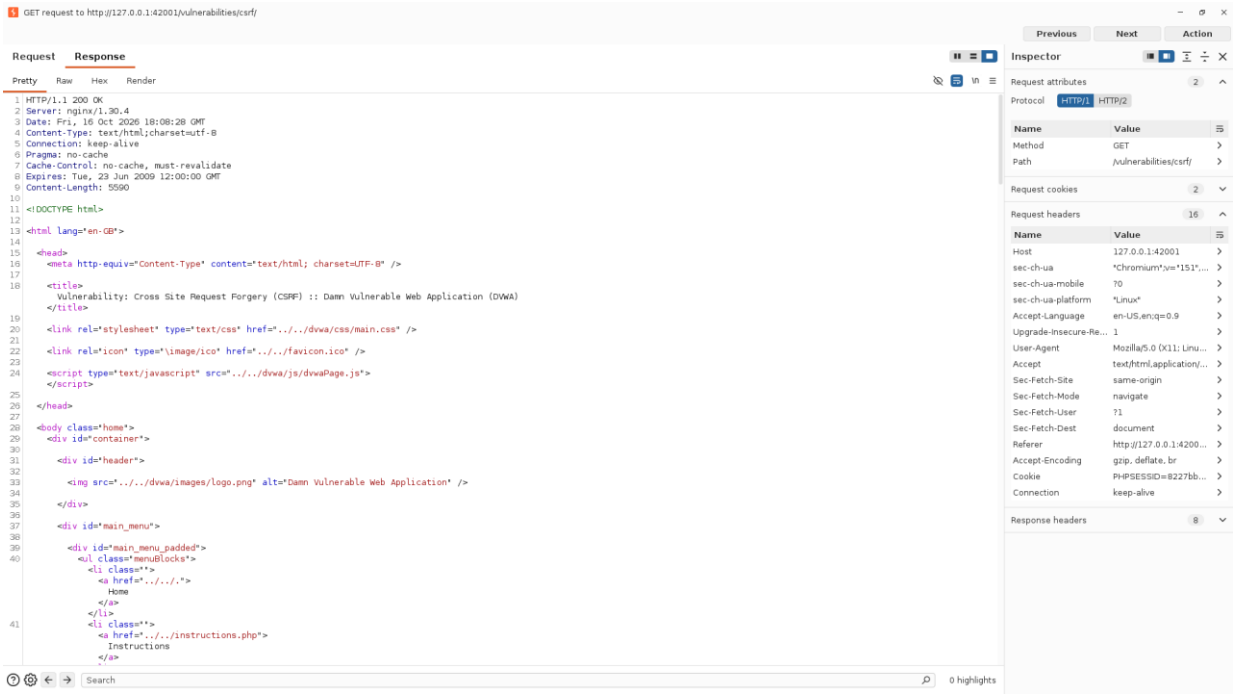


Fig 2: Burp Suite response showing the CSRF page returned with HTTP 200 OK.

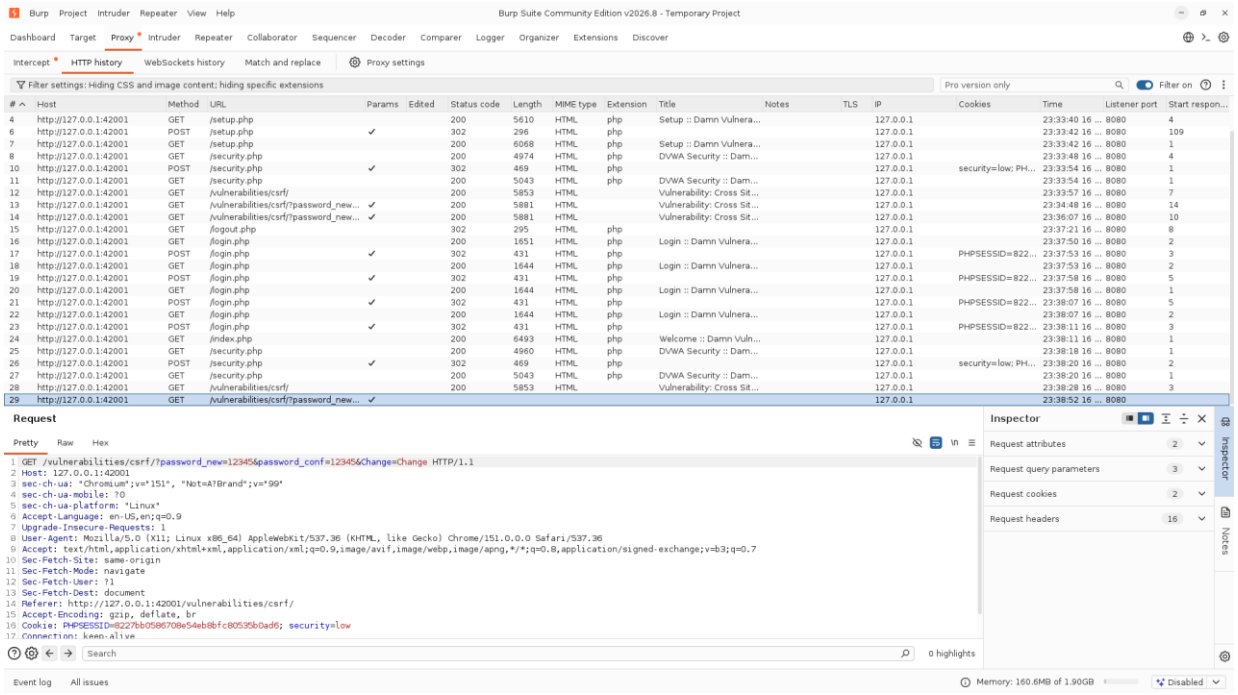


Fig 3: Burp Suite HTTP history and captured GET request containing password_new, password_conf, and Change parameters.

RESULT:

The DVWA CSRF password-change form was accessed at Low security and its HTTP request was inspected using Burp Suite. The captured form and request show no user_token parameter. The provided evidence includes an HTTP 200 OK response; however, a successful password change was not conclusively demonstrated by the supplied screenshots. The final result should be marked successful only after verifying the change with DVWA's Test Credentials control.